GANRICH
ADVISORY

TEKNİK NOT · AB PAZARINA ERİŞİM

Müşterinin yükümlülüğü, sizin kanıtınız: Türk tedarikçiler için NIS2 tedarik zinciri güvenliği

AB üye devletlerinin çoğu NIS2 Direktifini artık iç hukuka aktardı. Tedarik zinciri kuralları, Türk BT, yazılım ve sanayi tedarikçilerine sözleşmeler ve anketler yoluyla ulaşıyor.

Ahmed Furkan Gül, Kurucu, Ganrich Advisory

Ekim 2026

Yönetici özeti

1. (AB) 2022/2555 sayılı NIS2 Direktifi; enerji ve ulaştırmadan elektronik, makine ve motorlu araç üretimine kadar 18 sektördeki orta ve büyük kuruluşların siber güvenlik riskini, tedarik zincirindeki risk dahil, yönetmesini istiyor. İç hukuka aktarma için son tarih 17 Ekim 2024'tü. Üye devletlerin çoğu bu tarihi kaçırdı; ama 2026 baharında büyük çoğunluğu ulusal yasalarını kabul etmişti. Almanya'nın yasası 6 Aralık 2025'te yürürlüğe girdi.
2. 21. Madde, tedarik zinciri güvenliğini asgari önlemlerden biri yapıyor. AB'deki kuruluşlar her doğrudan tedarikçinin zafiyetlerini ve ürünlerinin ve güvenlik uygulamalarının kalitesini dikkate almak zorunda. Pratikte bunu anketler, sözleşme maddeleri, denetim hakları ve tedarikçilere yüklenen olay bildirim yükümlülükleriyle yapıyorlar.
3. Türk yazılım firması, yönetilen hizmet sağlayıcısı veya bağlantılı sanayi ekipmanı tedarikçisi için NIS2 nadiren doğrudan bir hukuki yükümlülük. Bir satış koşulu. Tek ve inandırıcı bir güvenlik kanıt paketi gösterebilen ve gerçekçi bir olay bildirimi taahhüdü veren tedarikçi sözleşmeyi koruyor; her anketi sıfırdan yanıtlayan ise zaman harcıyor ve yine de riskli görünüyor.

Ne değişti?

(AB) 2022/2555 sayılı Direktif ilk NIS Direktifinin yerini aldı ve kapsamı 18 sektöre genişletti. I. Ek; enerji, ulaştırma, bankacılık, sağlık, dijital altyapı ve BT hizmet yönetimi gibi yüksek kritiklikteki sektörleri sayıyor. II. Ek ise tıbbi cihaz, bilgisayar ve elektronik, elektrikli ekipman, makine ve motorlu araç imalatı dahil diğer kritik sektörleri sayıyor.

Üye devletlerin Direktifi 17 Ekim 2024'e kadar iç hukuka aktarması gerekiyordu. Avrupa Komisyonu 28 Kasım 2024'te 23 üye devlete resmî ihtar mektubu, 7 Mayıs 2025'te 19 üye devlete gerekçeli görüş gönderdi. Ulusal yasalar 2025 ve 2026 boyunca çıktı; bu yüzden AB müşterilerinin çoğunun artık taslak değil bağlayıcı yükümlülükleri var.

21. Madde; olay yönetimi, iş sürekliliği, güvenli geliştirme, erişim kontrolü ve tedarik zinciri güvenliği dahil asgari risk yönetimi önlemlerini sayıyor. 21(3). Madde, kuruluşlardan her doğrudan tedarikçiye ve hizmet sağlayıcıya özgü zafiyetleri ve ürünlerinin ve siber güvenlik uygulamalarının genel kalitesini dikkate almalarını istiyor. (AB) 2024/2690 sayılı Komisyon Uygulama Tüzüğü bu önlemleri dijital altyapı ve BT hizmet sağlayıcıları için ayrıntılı olarak tanımlıyor.

Kuruluşlar önemli olayları ulusal makamlara bildirmek zorunda: 24 saat içinde erken uyarı, 72 saat içinde olay bildirimi. Bir tedarikçi ihlali bir hafta sonra haber verirse bu süreleri karşılayamazlar; bu yüzden sözleşmeler artık tedarikçiler için de bildirim süreleri koyuyor.

Yönetim organları önlemleri onaylamak zorunda ve sorumlu tutulabiliyor. AB şirketlerindeki satın alma ve hukuk ekiplerinin tedarikçilere karşı daha talepkâr hale gelmesinin nedeni bu.

Türkiye'nin kendi çerçevesi var: 7545 sayılı Siber Güvenlik Kanunu 19 Mart 2025'te Resmî Gazete'de yayımlandı. AB müşterilerinin NIS2 kapsamında istediklerinin yerini tutmuyor, ama bazı kanıtlar ikisine birden hizmet edebilir.

Yükümlülüğün arkasındaki karar

Tedarikçinin kararı, bir kez ve iyi yanıt vermenin yolunu bulmak. AB müşterileri farklı biçimlerde birbiriyle örtüşen sorular soruyor: politikalar, erişim kontrolü, zafiyet yönetimi, yedekleme, alt yükleniciler, olay müdahalesi, belgeler. Müşterilerinin kullandığı başlıca çerçevelere göre eşleştirilmiş ve güncel tutulan bir kanıt paketi kuran tedarikçi, taleplerin çoğunu günler içinde yanıtlayabilir.

İkinci karar ticari. Bildirim süreleri, denetim hakları ve sorumluluk üzerine sözleşme maddeleri çok farklılık gösteriyor. 24 saatlik bildirim yükümlülüğünü kabul etmek, ancak tedarikçi bir olayı gerçekten bu sürede fark edip yükseltebiliyorsa makul. Karşılanamayacak koşulları kabul etmek risk yaratır; reddetmek müşteriyi kaybettirebilir.

Üçüncü karar, ISO/IEC 27001 gibi bir belgelendirmeye gidip gitmemek. Her soruyu yanıtlamaz, ama birçok AB alıcısı kontrol listesinin büyük bölümü için kanıt olarak kabul ediyor.

Sık yapılan beş yanlış okuma

"NIS2 AB hukuku, bize uygulanmaz." AB dışındaki tedarikçilere sözleşmeler yoluyla ulaşıyor. I. veya II. Ekteki sektörlerde AB iştiraki olan Türk grupları doğrudan kapsamda da olabilir.

"ISO 27001 belgesi konuyu kapatır." Yardımcı olur; ama müşteriler kapsamı, alt yüklenicileri, zafiyet yönetimini ve bildirim sürelerini yine soruyor.

"Yalnızca BT şirketleri etkileniyor." Bağlantılı makine, yazılım içeren bileşen ve üreticilere dış kaynak hizmeti sunan tedarikçiler de aynı soruları alıyor.

"Anket satışta bir formalite." Yanıtlar çoğu zaman sözleşme eki oluyor; yanlış yanıtlar sorumluluğa dönüşüyor.

"İç hukuka aktarma hâlâ sürüyor, bekleyebiliriz." Üye devletlerin çoğu yasalarını kabul etti ve müşteriler bunları güncel ihalelerde ve yenilemelerde uyguluyor.

Yönetim ekibi için sorular

1. AB müşterilerimizden hangileri NIS2 kapsamında temel veya önemli kuruluş ve hangi ülkelerde?
2. Son bir yılda güvenlik anketi veya yeni sözleşme maddesi aldık mı, nasıl yanıtladık?
3. Paylaşabileceğimiz güncel ve bakımı yapılan bir güvenlik politikaları ve kanıt setimiz var mı?
4. Bir müşteriyi etkileyen güvenlik olayını ne kadar hızlı fark edip bildirebiliriz?
5. Kendi alt yüklenicilerimizden ve bulut sağlayıcılarımızdan hangileri müşteri sistemlerini veya verisini etkileyebilir?
6. Sağladığımız yazılım veya cihazlardaki zafiyetleri nasıl yönetiyoruz?
7. ISO/IEC 27001 veya başka bir belgelendirme, müşteri sorularının çoğunu bizim için yanıtlar mı?
8. Sözleşmelerde verilen siber güvenlik taahhütlerinin yönetimdeki sahibi kim?

İyi bir ilk adımın ürettikleri

İyi bir ilk adım, bir tedarikçi güvenliği incelemesidir: başlıca AB müşterilerinizin sorduğu sorular, elinizdeki kanıtlar, eksikler ve gerçekçi olarak kabul edebileceğiniz sözleşme koşulları. Sonunda yönetimin elinde kurulacak tek bir kanıt paketi ve bildirim ile denetim maddelerine ilişkin bir tutum olmalı.

Ganrich Advisory bunu teknik, hukuk ve satış ekiplerinizle yürütür; gereken yerlerde güvenlik uzmanları ve belgelendirme kuruluşlarıyla çalışır. Belgelendirme kuruluşu değiliz ve sızma testi hizmeti vermiyoruz. Çalışma yöntemini, müşterilerinize bağlı olduğu için, basılı metinde değil görüşmede paylaşıyoruz.

Görüşme başlatın

furkangul@ganrichadvisory.com · ganrichadvisory.com

Bu not hakkında. Bu not, 24–25 Ekim 2026 tarihlerinde kontrol edilen resmî kaynaklara dayanır. Genel bilgi niteliğindedir; hukuki, gümrük, vergi veya mühendislik danışmanlığı değildir. Kurallar, eşikler ve tarihler değişebilir; harekete geçmeden önce resmî kaynaklardan teyit edin. Herhangi bir müşteri çalışmasını veya sonucunu anlatmaz.

Kaynaklar: (AB) 2022/2555 sayılı Direktif (NIS2): eur-lex.europa.eu/eli/dir/2022/2555/oj · (AB) 2024/2690 sayılı Komisyon Uygulama Tüzüğü: eur-lex.europa.eu/eli/reg_impl/2024/2690/oj · Avrupa Komisyonu, NIS2 Direktifi: digital-strategy.ec.europa.eu/en/policies/nis2-directive · 7545 sayılı Siber Güvenlik Kanunu, Resmî Gazete, 19 Mart 2025

© 2026 Ganrich Advisory